

INTERNAL SECURITY AUDIT REPORT

NIST Cybersecurity Framework (CSF) Assessment

Prepared For:

Botium Toys

Prepared By: Manuel Joe Sam Acquah Gaisey
Role: Security Analyst (Internal Audit Simulation)
Date: May 21, 2026
Location: Accra, Ghana

1. Executive Summary

This report presents the findings of a comprehensive internal security audit conducted on Botium Toys' IT environment. Using the NIST Cybersecurity Framework (CSF) as the baseline standard, the assessment thoroughly evaluated existing security controls, technical vulnerabilities, compliance posture, and overall organizational risk exposure across technical, administrative, and operational domains.

CRITICAL RISK RATING: HIGH (8/10)

The organization demonstrates foundational physical security controls; however, critical cybersecurity safeguards are completely missing or maturely deficient. These gaps significantly increase exposure to severe data breaches, substantial regulatory non-compliance fines, and paralyzing operational disruptions.

2. Audit Scope & Objectives

Scope

The scope of this internal audit encompassed a top-to-bottom review of Botium Toys' technical and organizational footprint, including:

- Core IT infrastructure, network boundaries, and technical security controls.
- Physical and digital assets, including endpoints, servers, and legacy systems.
- Internal data policies, user lifecycle management, and administrative access controls.
- Compliance readiness against key regulatory and industry standards (PCI DSS, GDPR, SOC 1 / SOC 2).

Objectives

The primary objectives directing this evaluation were:

- Identify critical security vulnerabilities, architectural flaws, and control gaps.
- Assess operational readiness and legal compliance against international data protection standards.
- Evaluate systemic risk exposure to critical business and customer data assets.
- Provide clear, prioritized, and actionable remediation recommendations aligned with the NIST CSF.

3. Key Risk Summary

The following high-priority risk areas were uncovered during the audit, representing immediate vectors for exploitation or regulatory enforcement actions:

- **Absence of Encryption:** Sensitive customer data and cardholder information are stored and transmitted in cleartext, creating an existential risk of exposure and directly violating basic PCI DSS mandates.
- **Lack of Threat Monitoring:** No Intrusion Detection System (IDS) or continuous threat monitoring framework is in place, meaning malicious activity or active network breaches could go completely unnoticed for indefinite periods.
- **No Disaster Resilience:** The total lack of formal backup schedules, disaster recovery documentation, and business continuity capabilities exposes the company to permanent data loss during ransomware incidents or hardware failures.
- **Weak Identity Governance:** Weak password management policies, an absent centralized directory/authentication system (e.g., Active Directory/IdP), and zero enforcement of multifactor authentication (MFA).
- **Privilege Creep:** Excessive user access privileges exist across multiple staff roles, with absolutely no technical enforcement of the principle of least privilege or formal separation of duties.
- **Unmanaged Assets:** The lack of a formalized asset inventory or data classification framework leaves the IT and security functions unable to defend what they do not explicitly track.

4. Security Controls Assessment

An evaluation of controls against typical security baselines reveals a stark imbalance between physical infrastructure defenses and modern cybersecurity protections.

Implemented Controls (Current Defenses)

- **Perimeter Firewall Protection:** Basic network edge filtering is implemented.
- **Antivirus Software:** Endpoint software deployed on user workstation fleets.
- **Legacy System Monitoring:** Manual checks are conducted periodically on older operational servers.
- **Physical Security Controls:** Robust physical defenses including commercial-grade door locks, CCTV networks, and facility alarm systems.
- **Environmental Safeguards:** Functioning fire detection and suppression systems across facilities.

Missing / Not Implemented Controls (Critical Gaps)

- Least privilege access control models and role-based access architectures.
- Formal separation of duties (SoD) frameworks for critical financial or technical operations.
- Network or Host-based Intrusion Detection Systems (IDS).
- Data encryption mechanisms for sensitive text both at rest and in transit.
- Centralized password and identity management system.
- Strong, technically-enforced password policy frameworks (complexity, length, rotational schedules).
- Automated regular data backups and offsite resilience strategies.

- Disaster recovery (DR) and business continuity (BC) operational plans.
- Formal enterprise asset inventory and data classification frameworks.

5. Compliance Assessment

A strict validation of Botium Toys' current posture against leading international compliance frameworks reveals major gaps that present severe legal and financial liabilities.

PCI DSS Compliance Status

Requirement Domain	Current Status
Protection of cardholder data	Not Implemented
Secure data storage/processing	Not Implemented
Encryption of sensitive data	Not Implemented
Secure authentication controls	Not Implemented

Overall PCI DSS Status: **NON-COMPLIANT**

GDPR Compliance Status

Requirement Domain	Current Status
Data protection measures	Not Fully Implemented
72-hour breach notification plan	Implemented
Data classification and inventory	Not Implemented
Privacy policy enforcement	Implemented

Overall GDPR Status: **PARTIALLY COMPLIANT**

SOC 1 / SOC 2 Alignment Profile

Trust Services Criteria	Current Status
Access control mechanisms	Not Implemented
Data confidentiality	Not Fully Implemented
Data integrity	Implemented

Data availability	Implemented
-------------------	-------------

Overall SOC Readiness: **PARTIAL COMPLIANCE Alignment**

6. Recommendations

To systematically mitigate identified organizational risks, align with the NIST CSF framework, and achieve legal compliance, Botium Toys should immediately implement the following technical and administrative controls:

Access & Identity Security

- **Enforce Least Privilege Controls:** Restrict broad file and directory permissions across roles; provision user permissions strictly based on documented requirements necessary to fulfill job tasks.
- **Implement Separation of Duties (SoD):** Divide high-risk tasks (e.g., financial management and IT data modifications) among multiple personnel to prevent single-source fraud or accidental mass compromise.
- **Deploy Centralized Identity Management:** Introduce a centralized Identity Provider (IdP) or directory service (such as Active Directory) to oversee user provisioning, password rotation, and facilitate enterprise-wide Single Sign-On (SSO).
- **Enforce Strong Password Policies:** Mandate technical password parameters requiring a minimum length, complex character sets, regular rotation schedules, and require Multifactor Authentication (MFA) across all endpoints.

Technical Security Controls

- **Implement Comprehensive Encryption:** Enforce Advanced Encryption Standard (AES-256) for all sensitive client and transaction data at-rest within databases and storage drives, alongside TLS 1.3 encryption configurations for data-in-transit.
- **Deploy an Intrusion Detection System (IDS):** Integrate host-based and network-based monitoring sensors to detect, alert, and flag suspicious lateral movements or unauthorized anomalies.
- **Establish Backup and Disaster Recovery:** Create automated, immutable data backups adhering to the 3-2-1 rule (3 copies, 2 media types, 1 offsite location), coupled with regular recovery simulation drills and formalized business continuity policies.

Governance & Asset Management

- **Establish Asset Inventory and Classification:** Conduct a comprehensive discovery campaign to index all hardware and software components, categorizing information according to sensitivity thresholds.
- **Introduce Continuous Monitoring and Logging:** Centralize system event logs into a secure server to enable retroactive forensics and provide transparent compliance tracking.

7. Conclusion

While Botium Toys successfully manages baseline physical facility protections, the current state of its digital infrastructure presents acute operational, financial, and regulatory liabilities. The absence of cornerstone mechanisms like modern data encryption, access limitation frameworks, threat detection systems, and verifiable recovery pathways creates a highly volatile technical risk posture.

Executing the security remediations outlined within this report is a business imperative. Immediate mitigation steps will dramatically improve technical resilience, guarantee strict data safety boundaries required by PCI DSS and GDPR frameworks, and align corporate processes with industry-leading NIST CSF standards, positioning Botium Toys securely for future operational growth.